

Vulnerability & Compliance Executive Report

System: T-Pot O&G Threat Intelligence Honeypot Lab **Prepared For:** Leadership / Authorizing Official (AO) **Prepared By:** Marcus **Date:** August 12, 2026 **Status:** System decommissioned — this is the final report for this system’s lifecycle **Supporting Documents:** System Security Plan (SSP), Security Assessment Plan (SAP), Security Assessment Report (SAR) — full technical detail lives in those documents; this report summarizes for a non-technical audience.

Purpose

This system was a research honeypot lab built to demonstrate applied RMF practice: deploy a system, document it (SSP), plan how to assess it (SAP), assess it against real tools, report findings with appropriate context, remediate or formally close what needed action, and retire the system cleanly. This report is the leadership-facing summary of that full cycle.

Bottom Line

No unresolved risk remains. Every finding identified during the assessment cycle was either remediated, validated as expected/by-design behavior, or formally closed through documented system decommissioning — a recognized RMF closure path, not a shortcut. Two process lessons were captured and carried forward into the checklist for future deployments of this kind.

What Was Assessed

Assessment	Result
Manual control review (identity, network boundary, encryption, monitoring)	Passed — all reviewed controls implemented as designed
OpenSCAP CIS Level 2 configuration scan	Scan did not produce usable results (tooling/execution issue); could not be re-run before the system was retired
Nessus credentialed vulnerability scan	Completed successfully; 78 distinct findings identified and evaluated

What the Findings Actually Meant

This system was a *honeypot* — a decoy platform designed to look vulnerable in order to attract and study attacker behavior. That context matters for how findings should be read:

- **Most flagged “vulnerabilities” were the system working as intended.** An old, unpatched database service and an open Telnet port aren’t oversights on a honeypot — they’re the bait. Each flagged service was checked against the system’s documented design and confirmed to be an intentional decoy, not an accidental exposure.
- **One finding had genuine security relevance:** whether a compromised decoy service

could reach Azure's internal metadata service and pivot toward cloud account information. This is now a required pre-deployment check for any future system of this type, since the original system was retired before it could be tested.

- **One documentation gap was found and corrected:** the system's on-file configuration record didn't match what was actually running (a routine patching drift), and was updated to reflect reality.

Risk-Based Recommendations

1. **For this system:** none — it is decommissioned and no further action is required.
2. **For future deployments of this kind:**
 - Verify automated compliance scanning tools are actually producing valid results (not silently returning "not applicable" for everything) before relying on them as evidence.
 - Test cloud-metadata-service isolation *before* decommissioning, not as an afterthought.
 - Keep the system's documentation in sync with automated patching so the on-file baseline doesn't drift from the running system.
3. **Process value demonstrated:** this engagement completed the full assess → report → remediate/close cycle expected under RMF, including honest handling of a scan that failed and a system retired before every item could be closed through remediation.

Audit Trail

Full technical detail — control-by-control mapping to NIST SP 800-53, raw scan data, plugin-level findings, and the complete POA&M — is maintained in the accompanying SSP, SAP, and SAR for audit purposes.